

MODULE 4 · CHOOSING AI FOR YOUR LAW FIRM

Five Security Questions + Answer Log

Send in writing. Get answers in writing. Written answers behave differently from demo answers.

The five questions

#	Question	Vendor answer (attach)	Pass?
1	Show two users with different permissions asking the same question and getting different answers — live, our environment, our documents.		☐
2	What exactly is retained, for how long, and who at your company can see it? (prompts, retrieved documents, outputs)		☐
3	Describe your controls against prompt injection. Specific mechanisms.		☐
4	What can this system do without a human approving it? Complete list of actions and connectors.		☐
5	Export the full audit trail for a single answer — prompt, retrieved sources, output, reviewer, timestamp, access since.		☐

Question 5 is the separator. If they cannot produce that record for one answer today, you will not be able to produce it for a client in a year.

Scoring notes

“We take security seriously” is a failed answer to question 3. A claim to have *solved* prompt injection is a competence signal *against* the vendor — nobody has.

The four binary safety gates

These are pass/fail, not scored. A vendor failing one is out regardless of everything else.

- ☐ Citations accurately support the claims attached to them
- ☐ Retrieval draws only from approved sources
- ☐ No unauthorized data is disclosed to any user
- ☐ The system declines appropriately when it should not answer

